Secretaría de Educación

DIRECCIÓN GENERAL DE UNIVERSIDADES TECNOLÓGICAS y POLITÉCNICAS

Universidad Tecnológica de Tehuacán

UNIVERSIDAD TECNOLÓGICA DE TEHUACÁN

INGENIERÍA EN DESARROLLO Y GESTIÓN DE SOFTWARE

Nombre del estudiante:
Concepción Guadalupe Paniagua González

Asignatura:
Desarrollo Web Profesional

Docente:
José Miguel Carrera Pacheco

Octavo Cuatrimestre Grupo “A”

S - 9. Arquitectura de autenticación y control de roles

¿Qué es autenticación y en qué se diferencia de autorización?

La autenticación se basa en "factores", elementos que un usuario posee o puede presentar para demostrar su identidad. La autorización se basa en "permisos", que definen lo que un usuario autenticado puede y no puede hacer.

¿Qué son JWT, sesiones y OAuth?

- El JWT es un formato de token compacto y seguro para URL, utilizado principalmente para transmitir información entre partes de forma segura. Es un objeto JSON que puede codificar diversas declaraciones, como la identidad del usuario y sus atributos. La ventaja de los JWT reside en su carácter autónomo, lo que significa que el token contiene toda la información necesaria, la cual se verifica mediante firmas digitales.

- La autenticación por sesión mantiene el estado en el servidor. Cuando un usuario inicia sesión, el servidor crea una sesión y guarda un identificador único asociado a la cuenta del usuario. Ese identificador se envía al cliente, normalmente en una cookie, y en cada petición posterior el servidor consulta su almacén de sesiones para validar la identidad y permisos del usuario.

- OAuth es un marco de autorización, define una serie de flujos, o "tipos de concesión", que permiten a una aplicación cliente acceder a recursos en nombre de un usuario. OAuth implica la obtención de un "token de acceso", que el cliente utiliza para autenticar las solicitudes a un servidor de recursos.

¿Cuándo conviene usar tokens y cuándo sesiones?

Conviene usar **sesiones** en aplicaciones web tradicionales (monolitos) donde el servidor necesita un control total y en tiempo real sobre quién está conectado (como en un banco o e-commerce).

Conviene usar **tokens** (como JWT) al construir APIs, aplicaciones móviles o sistemas distribuidos, ya que permiten que el servidor sea 'stateless' (sin estado), facilitando que el sistema crezca (escalabilidad) sin consumir memoria extra en el servidor para recordar a cada usuario

¿Qué riesgos de seguridad existen en un mal diseño de autenticación?

- Los ataques de phishing son técnicas comunes que los atacantes utilizan para obtener credenciales de acceso
- Contraseñas débiles y reutilizadas
- Ataques de fuerza bruta
- Secuestro de sesión

- Acceso no autorizado a cuentas privilegiadas

¿Cómo se definen roles y permisos en sistemas reales?

Se hace por medio del control de acceso basado en roles (RBAC) es un método de seguridad que gestiona el acceso a sistemas informáticos y datos según el rol del usuario dentro de una organización. Funciona así:

- Roles: Definen diferentes funciones dentro del sistema. Algunos ejemplos podrían ser "administrador", "editor" o "lector". Cada rol tiene un conjunto específico de permisos asociados.
- Permisos: Especifique las acciones que un usuario puede realizar dentro del sistema. Esto podría incluir ver archivos, editar documentos o aprobar transacciones.
- Usuarios: Se les asigna uno o más roles según sus responsabilidades laborales. Los permisos de un usuario se determinan según la combinación de sus roles asignados.

Bibliografía

Authentication vs authorization: Similarities and 5 key differences. (2024, agosto 19). *Frontegg*. https://frontegg.com/blog/authentication-vs-authorization

Fatunmbi, T. (2022, febrero 8). A comparison of cookies and tokens for secure authentication. *Okta Developer*. https://developer.okta.com/blog/2022/02/08/cookies-vs-tokens

Manor, G. L. (2024, enero 8). OAuth vs. JWT: What's the difference for application development. *Permit.Io*. https://www.permit.io/blog/differences-between-oauth-vs-jwt

Sesión vs JWT: Cómo funcionan, diferencias y ejemplos. (s/f). Q2bstudio.com. Recuperado el 9 de marzo de 2026, de https://www.q2bstudio.com/nuestro-blog/14738/sesion-vs-jwt-como-funcionan-diferencias-y-ejemplos?scriptscookies=1

(S/f). Coro.net. Recuperado el 9 de marzo de 2026, de https://www.coro.net/blog/the-importance-of-user-roles-and-permissions-in-cybersecurity-software